



# ETHICAL HACKER MASTER ROADMAP

*From Complete Beginner → Professional Penetration Tester*

## VERSION

v2.0 — Reviewed & Upgraded by Your Personal Cybersecurity Mentor

## ORIGINAL PLAN

7 steps — good foundation, missing certifications, checkpoints & depth

## UPGRADED PLAN

8 Phases with skill gates, certifications, lab milestones & real checkpoints



## ROADMAP OVERVIEW — THE BIG PICTURE

*Think of this roadmap like building a skyscraper. You cannot start on floor 10 without floors 1-9 being solid. Each phase is a floor. Each floor has a completion test — a checkpoint — before you go higher. The people who skip floors are the ones who get stuck, frustrated, and quit.*

| # | PHASE                                   | DURATION    | CATEGORY     | GATE                        |
|---|-----------------------------------------|-------------|--------------|-----------------------------|
| 1 | Foundations: Linux, Networking & Python | 4–6 weeks   | FOUNDATION   | Pass HTB Starting Point     |
| 2 | Web Security & OWASP Top 10             | 4–6 weeks   | CORE         | Complete DVWA + PortSwigger |
| 3 | Lab Setup & Hands-On Practice           | Ongoing     | CORE         | Root 5 Easy HTB Machines    |
| 4 | Network Pentesting Fundamentals         | 4–6 weeks   | ADVANCED     | Pass eJPT Exam              |
| 5 | Bug Bounty Hunting                      | Ongoing     | ADVANCED     | First Valid Bug Report      |
| 6 | Certifications Path                     | 6–12 months | PROFESSIONAL | CompTIA Sec+ → OSCP         |
| 7 | Learn from the Masters                  | Ongoing     | HABIT        | Daily Practice              |
| 8 | Stay Sharp & Build Reputation           | Ongoing     | EMPIRE       | Public Profile Built        |

|                |                                                    |                                |
|----------------|----------------------------------------------------|--------------------------------|
| <b>PHASE 1</b> | <b>FOUNDATIONS: Linux, Networking &amp; Python</b> | <b>4–6 Weeks</b><br>FOUNDATION |
|----------------|----------------------------------------------------|--------------------------------|

*This is your bedrock. Every single attack technique you will ever learn sits on top of these three pillars. Skipping or rushing this phase is like trying to run before you can walk — you'll fall, hard, in Phase 3.*

### **Linux & Command Line**

- Learn to navigate the filesystem: ls, cd, pwd, find, locate
- File permissions: chmod, chown, sudo — understand them deeply
- Process management: ps, top, kill, netstat, ss
- Text manipulation: grep, awk, sed, cat, less, tail
- Bash scripting: write scripts that automate repetitive tasks
- RESOURCE: TryHackMe 'Linux Fundamentals' rooms (free)

### **Networking**

- TCP/IP model — how data actually travels across the internet
- IP addressing, subnetting (CIDR notation) — this trips up beginners
- DNS, DHCP, HTTP/HTTPS, FTP, SSH — know what each protocol does
- How a packet moves: client → router → ISP → server → response
- Tools: Wireshark (packet capture), ping, traceroute, nslookup
- RESOURCE: Professor Messer's CompTIA Network+ (free on YouTube)

### **Python for Hackers**

- Variables, loops, functions, file I/O — the basics
- Working with requests library — interact with web APIs
- Socket programming — understand how network connections work
- Write a simple port scanner from scratch (your first real hacker tool!)
- RESOURCE: automate.py or 'Python for Everybody' on Coursera

|                                                                                                         |                                                                                                                         |
|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
|  <b>PHASE 1 GATE</b> | Complete TryHackMe 'Pre-Security' path + write one Python script that scans ports. If you can do that, move to Phase 2. |
|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|

|                |                                        |                  |
|----------------|----------------------------------------|------------------|
| <b>PHASE 2</b> | <b>WEB SECURITY &amp; OWASP TOP 10</b> | <b>4–6 Weeks</b> |
|----------------|----------------------------------------|------------------|

Web applications are where 80% of real-world bug bounty money lives. The OWASP Top 10 is your bible. Learn each vulnerability until you can explain it to a 10-year-old AND exploit it in a lab.

| SKILL / TOPIC              | RESOURCE                 | GOAL                             |
|----------------------------|--------------------------|----------------------------------|
| SQL Injection (SQLi)       | PortSwigger Web Academy  | Dump a database manually         |
| Cross-Site Scripting (XSS) | PortSwigger Web Academy  | Steal a cookie via XSS           |
| Broken Authentication      | DVWA + HTB               | Bypass a login form              |
| Security Misconfiguration  | TryHackMe rooms          | Find exposed admin panels        |
| Sensitive Data Exposure    | PortSwigger              | Extract credentials from traffic |
| CSRF                       | PortSwigger Web Academy  | Build a working CSRF PoC         |
| SSRF                       | HackTricks + PortSwigger | Hit internal AWS metadata        |
| XXE                        | PortSwigger Web Academy  | Read /etc/passwd via XML         |
| Broken Access Control      | DVWA                     | Access admin as regular user     |
| Insecure Deserialization   | PortSwigger              | Achieve RCE via object           |

### Tools to Master in This Phase

- Burp Suite Community Edition — your most important tool. Learn it deeply.
- OWASP ZAP — good alternative, especially for automation
- curl — make HTTP requests from command line
- Postman — test and manipulate APIs

#### ✓ PHASE 2 GATE

Complete PortSwigger Web Academy 'Apprentice' level labs for SQLi, XSS, and CSRF. These are free and world-class. If you pass those, you understand web security.

Reading about hacking is like reading about swimming. At some point you have to get in the water. Your lab is your pool. Set it up properly and protect yourself legally.

## Your Home Lab Stack

- Kali Linux — install as VM via VirtualBox or VMware (never as main OS when starting)
- VirtualBox — free virtualization software (VMware Workstation Pro is now free too)
- DVWA (Damn Vulnerable Web App) — run locally via Docker
- Metasploitable 2 — deliberately vulnerable Linux VM for practice
- VulnHub — download vulnerable VMs to attack offline (100% legal)

## Online Practice Platforms

- TryHackMe — best for beginners, guided rooms, browser-based (START HERE)
- Hack The Box — harder, more realistic, community is elite
- PortSwigger Web Academy — the single best free web security training on the planet
- PentesterLab — great for web application security with graded exercises

### PHASE 3 GATE

Root (get admin/root access on) 5 'Easy' difficulty machines on Hack The Box. Write a short writeup for each. This proves you can apply what you learned.

### LEGAL WARNING

NEVER practice on systems you don't own or have written permission to test. This is not just ethics — it's federal law (CFAA in the US, Computer Misuse Act in the UK). Your lab exists so you never have to break this rule.

## PHASE 4

## NETWORK PENTESTING FUNDAMENTALS

4–6 Weeks  
ADVANCED

Web hacking is one dimension. Network pentesting is the full three-dimensional chess game. This is where you learn to think like an attacker moving through an entire company's infrastructure — not just one website.

## Core Skills

- Nmap — network scanning, service detection, OS fingerprinting (master this tool)
- Metasploit Framework — understand exploit modules, payloads, sessions
- Enumeration — SMB, FTP, SSH, HTTP services — what info can you extract?
- Password attacks — Hydra, John the Ripper, Hashcat — cracking hashes
- Privilege escalation — once you're in, how do you become admin?
- Post-exploitation — what do you do after you have access?

## Your First Certification: eJPT

eLearnSecurity Junior Penetration Tester (eJPT) — this is the PERFECT first cert for you.

- Cost: ~\$200 for exam voucher + free course (INE Starter Pass)
- Difficulty: Beginner-friendly but requires real skills
- Format: Practical exam — you hack a real network, no multiple choice
- Value: Proves you can actually do this. Employers respect it.
- Timeline: Study 4-6 weeks, pass the exam, add to LinkedIn immediately

✓ **PHASE 4  
GATE**

Pass the eJPT exam. This is non-negotiable. If you complete Phase 4 without the cert, you have knowledge but no proof. The cert IS the gate.

**PHASE 5**

**BUG BOUNTY HUNTING**

**Ongoing  
ADVANCED**

Bug bounty is where your skills meet real money for the first time. It is also where most beginners get humbled — and that's a good thing. The humbling teaches you faster than any course.

🎯 **Platform Hierarchy (Start Here, In Order)**

- 1st: TryHackMe / HTB CTFs — zero legal risk, pure skill building
- 2nd: HackerOne — largest platform, huge scope variety, good for beginners
- 3rd: Bugcrowd — strong community, good beginner programs
- 4th: Open Bug Bounty — free programs, good starting point
- 5th: Synack Red Team — invite only, you apply after building a track record

📝 **How to Write a Report That Gets Paid**

- Title: One sentence describing the vulnerability and impact
- Severity: CVSS score — learn to calculate this properly
- Steps to Reproduce: Numbered, clear, someone else can follow them
- Proof of Concept (PoC): Screenshot, video, or code proving the bug exists
- Impact: What is the WORST CASE if an attacker exploits this?
- Remediation: How should the company fix it?

**PRO TIP**

Read 50 disclosed HackerOne reports BEFORE you hunt. Go to [hackerone.com/hackactivity](https://hackerone.com/hackactivity) and read reports for the vulnerability types you want to find. You are studying the map before entering the jungle.

✓ PHASE 5  
GATE

Submit your first valid bug report on any platform. Even a low/info severity. The goal is completing the full cycle: find → document → report → receive response.

PHAS  
E 6

CERTIFICATIONS PATH

6–12 Months  
PROFESSIONAL

Certifications are your professional armor. They don't make you a hacker — your skills do that. But they make clients trust you with their systems, unlock job opportunities, and justify your rates. Here is the exact sequence.

| # | CERTIFICATION         | COST      | WHEN TO TAKE               | WHY IT MATTERS                                                                         |
|---|-----------------------|-----------|----------------------------|----------------------------------------------------------------------------------------|
| 1 | CompTIA Security+     | ~\$400    | After Phase 2-3            | Industry baseline. Required by US government contractors. HR loves it.                 |
| 2 | eJPT (eLearnSecurity) | ~\$200    | After Phase 4              | First PRACTICAL cert. Proves hands-on skill, not just memorization.                    |
| 3 | CompTIA PenTest+      | ~\$400    | After eJPT                 | Bridges theory and practice. Good stepping stone to OSCP.                              |
| 4 | CEH (EC-Council)      | ~\$1,000+ | Optional                   | Corporate recognition. Controversial in the community. Useful for certain job markets. |
| 5 | OSCP (OffSec)         | ~\$1,499  | After 6-12 months practice | THE gold standard for penetration testing. Opens all doors. Respected globally.        |

🏆 THE OSCP  
REALITY  
CHECK

OSCP is a 24-hour practical exam where you hack into real machines. It is brutal. It is elite. It is worth every penny and every sleepless night. When you have OSCP after your name, you don't need to prove anything to anyone in a job interview. Plan for this to take 1-2 years of serious preparation from where you are now.

PHAS  
E 7

LEARN FROM THE MASTERS

Ongoing  
HABIT

The best hackers are obsessive learners. They don't just practice — they study other people's thinking. Here is your curated intelligence feed.

### YouTube Channels (Watch Weekly)

- @TheCyberMentor (TCM) — best beginner-to-intermediate content on the planet
- @STÖK — bug bounty mindset, methodology, and real hunter insights
- @NahamSec (Ben Sadeghipour) — live bug bounty sessions, beginner-friendly
- @lppSec — HTB machine walkthroughs. Watch AFTER you try the machine first.
- @LiveOverflow — deep technical content, binary exploitation, CTF analysis

### Read Write-Ups (Your Daily Newspaper)

- HackerOne Hacktivity — disclosed real bug reports with full details
- Bugcrowd Disclosure — similar, different platforms and vulnerabilities
- PentesterLand write-up compilation — weekly newsletter of the best writeups
- Medium.com/infosec — search any vulnerability type + writeup

### Books That Are Worth Your Time

- 'The Web Application Hacker's Handbook' — foundational web security bible
- 'Penetration Testing' by Georgia Weidman — practical and beginner-friendly
- 'Hacking: The Art of Exploitation' — deep technical, for when you're ready

#### ✓ PHASE 7 HABIT

Spend 30 minutes every day reading one writeup OR watching one technical video. Compound learning is how you go from beginner to expert in 18 months instead of 5 years.

## PHASE 8

## STAY SHARP & BUILD YOUR REPUTATION

## Ongoing EMPIRE

Technical skill is 60% of the game. The other 40% is reputation. The hackers who get invited to private programs, get hired by top firms, and get paid \$20,000 for a single bug — they have reputation. Here is how you build it.

### Build a Public Presence

- Twitter/X — share what you learn. Post one thing per day. Tag researchers.
- LinkedIn — document every certification, every platform achievement, every milestone
- GitHub — push your scripts, tools, and automation. Code is your resume.
- Personal Blog / Medium — write about machines you rooted, bugs you found (after disclosure)

## Community & Live Events

- HackerOne H1-events — live hacking events, invitation builds over time
- DEF CON / Black Hat — attend virtually first, in person when possible
- CTF competitions — team up on CTFtime.org events
- Discord servers: TryHackMe, HTB, NahamSec, TCM Security

## Stay Current (Security Moves Fast)

- Follow CVEs at [cve.mitre.org](https://cve.mitre.org) and NVD (national vulnerability database)
- Krebs on Security ([krebsonsecurity.com](https://krebsonsecurity.com)) — top security journalism
- The Hacker News ([thehackernews.com](https://thehackernews.com)) — daily security news
- [r/netsec](https://www.reddit.com/r/netsec) and [r/bugbounty](https://www.reddit.com/r/bugbounty) on Reddit — community discussions

### ✓ PHASE 8 GATE

By the time you reach Phase 8, you should have: a GitHub with your tools, a LinkedIn showing your certs, at least one public writeup or blog post, and a Hall of Fame mention on any bug bounty platform.

## WHAT YOUR ORIGINAL PLAN WAS MISSING

| ORIGINAL PLAN HAD        | WHAT WAS MISSING             | WHY IT MATTERS                                  |
|--------------------------|------------------------------|-------------------------------------------------|
| Web security (OWASP)     | Network pentesting phase     | 75% of jobs require network skills too          |
| Lab tools listed         | Skill checkpoints/gates      | Without gates, you never know when you're ready |
| Bug bounty mentioned     | Certification roadmap        | Certs = proof = clients = money                 |
| Python mentioned briefly | Python for hackers depth     | Python is your #1 automation weapon             |
| Community mentioned      | Reputation building strategy | Reputation multiplies your opportunities 10x    |
| DVWA / HTB listed        | Specific learning order      | Wrong order = frustration and wasted months     |
| Final advice: be patient | Timeline expectations        | You need to know how long each phase takes      |



## REALISTIC TOTAL TIMELINE

Here is the honest truth most roadmaps won't tell you. Based on 1-2 hours of daily study and practice:

| MILESTONE                   | MINIMUM TIME | REALISTIC TIME | KEY UNLOCK               |
|-----------------------------|--------------|----------------|--------------------------|
| Linux + Networking + Python | 4 weeks      | 6–8 weeks      | First HTB machine        |
| Web Security (OWASP + Labs) | 4 weeks      | 6–8 weeks      | First bug bounty attempt |
| eJPT Certification          | 2 months     | 3–4 months     | First line on resume     |
| CompTIA Security+           | 3 months     | 4–6 months     | Corporate job eligible   |
| 100 HTB/THM Machines        | 6 months     | 12–18 months   | OSCP ready               |
| OSCP Certification          | 12 months    | 18–24 months   | Top 5% of field          |
| First Bug Bounty Payout     | 3 months     | 6–12 months    | Real-world validation    |

## THE GOLDEN RULES OF YOUR JOURNEY

### RULE 1

Never skip a phase gate. If you can't pass the gate, you're not ready. Stay and practice.

### RULE 2

Build as you learn. Every script, every tool, every writeup goes to GitHub. Your journey IS your portfolio.

### RULE 3

Community accelerates everything. One conversation with a senior researcher can save you 3 months of confusion.

### RULE 4

ALWAYS be legal. Written permission only. Your lab exists so you never need to test anything unauthorized.

### RULE 5

Consistency beats intensity. 1 hour every day beats 7 hours every Sunday. The compound effect is real.

### RULE 6

Document everything. Future n3o will thank current n3o for clear notes, writeups,

and LESSONS files.

---

**n3o | Ethical Hacker Master Roadmap | Version 2.0**

*"The expert in anything was once a beginner who refused to quit."*